

Board Memo - Joint SOC 2 + PCI DSS Compliance Programme

TO: Risk Committee / Audit Committee of the Board
FROM: Chief Information Security Officer (CISO)
SUBJECT: Joint SOC 2 + PCI DSS v4.0 Compliance Programme
DATE: 01 July 2026
REF: NBFC/2026/CISO/JOINT-PROG/001

Purpose	Seek approval to run SOC 2 Type II and PCI DSS Service Provider Level 1 ROC as a single integrated programme. Combined run delivers ~30% lower engineering-hours, ~15-20% lower audit fees, and a unified board reporting cadence. NBFC touches card data AND enterprise customers; running separately doubles work and splits the audit month in two.
Recommendation	Approve the joint programme. Authorise a single SteerCo (CISO + CRO + CFO + CTO), single GRC (Vanta or Drata), single 18-month roadmap, and budget of INR 1.9-3.1 crore for cycle 1. Authorise the CISO to launch by week 4 with vendor selection complete by week 6.
Why now	1) Enterprise customers (banks, B2B SaaS, marketplaces) demand SOC 2 Type II before onboarding - current absence blocks sales. 2) Acquirer / card networks mandate annual PCI ROC for NBFC card data. 3) RBI IT Framework 2023 + DPDP Act 2023 + Tokenisation 2021/2023 layer regulatory weight. Two parallel programmes double engineering load; one halves it.

Quantified wins (joint vs separate)

KPI	Separate run	Joint run	Delta
Engineering FTE-hours / qtr	1,400-1,800	950-1,200	-30%
Annual audit fees	INR 1.8-3.0 cr	INR 1.5-2.4 cr	-15 to -20%
Audit findings at first cycle	12-15	7-9	-40%
SOC 2 + PCI delivery days	270 days	210 days	-22%
Enterprise sales cycle	120 days	75 days	-37%
Compliance dashboards BAU	5-7	1 unified cockpit	Single source

Risk Committee ask - six decisions

Action	Detail	When	Owner
Approve	Joint SOC 2 + PCI DSS programme structure + 18-month roadmap	Today	Risk Committee
Authorise	INR 1.9-3.1 crore total cycle 1 budget	Today	Risk Committee
Charter	Combined SteerCo chaired by CRO; CISO leads delivery	Week 2	CISO + CRO
Vendor	Select QSA + CPA auditor pair + GRC tool	Week 4	CFO + CISO
Programme	Mobilise SteerCo + evidence repository + RACI	Week 6	CISO
Window	Begin first joint observation window	Week 12	CISO

Top four risks and mitigations

Risk	Description	Mitigation
Two parallel programmes	Engineering burnout + duplicated controls	Joint SteerCo + shared evidence + shared GRC tool
Audit date collision	SOC 2 + PCI in same month	Sequential fieldwork; PCI Sep-Oct, SOC 2 Jan-Feb
Vendor AOC expiry slip	Vendor SOC 2 or PCI AOC expires quietly	Quarterly CISO review + automated calendar alerts
RBI 2-hour timer	Cyber incident hits the cliff	Quarterly tabletop + parallel clocks playbook

Specific decisions requested

Action verb	Decision text
Approve	Joint SOC 2 + PCI DSS programme structure and 18-month roadmap
Authorise	INR 1.9-3.1 crore cycle 1 budget
Charter	Combined SteerCo chaired by CRO, CISO-led execution
Schedule	First joint observation window start by 30 Sep 2026
Authorise	CISO to negotiate single GRC tool capex <= INR 65 lakh

Closing: Programme charter with detailed milestones, vendor shortlist and contingencies will be circulated post-approval under separate cover. Submitted for Risk Committee review.

- CISO | Reviewed: CFO | Reviewed: CRO